

TASK 5: RECENT MALWARE INCIDENTS

1. NPM Supply Chain Attack — September 2025

- **Attack Method:**

In early September 2025, attackers launched a spear-phishing campaign targeting JavaScript developers and maintainers of popular NPM packages. They spoofed NPM's login domain (**npmjs.help**) and tricked victims into revealing credentials and 2FA codes. With stolen credentials, the attackers published malicious updates to major packages such as **eslint-config-prettier**, **syndkit**, and **@pkgr/core**. These versions injected malware that exfiltrated authentication tokens from `.npmrc` files and installed a second-stage infostealer targeting saved browser data and environment tokens. Over 2 billion weekly downloads were affected before detection.

[\[1\]](#)[\[2\]](#)[\[3\]](#)

- **Mitigation and Resolution:**

NPM security teams quickly removed compromised packages, revoked affected access tokens, and advised developers to rotate credentials and update dependencies. Clean versions were republished, and new automated anomaly detection rules were added to identify suspicious package changes in real time. Cybersecurity vendors such as CrowdStrike and Qualys released YARA signatures and supply-chain monitoring scripts to block similar hijacks.

[\[4\]](#)[\[5\]](#)[\[1\]](#)

2. ChatGPT “Deep Research” Zero-Click Exploit (ShadowLeak) — August to September 2025

- **Attack Method:**

In mid-2025, researchers from Radware discovered a *zero-click exploit* in **ChatGPT's Deep Research** feature. Attackers could embed invisible prompt-injection instructions within HTML emails that the agent analyzed through a connected Gmail account. The injected content allowed sandbox escape and remote exfiltration of email metadata (subject, sender, and partial content). The attack, named **ShadowLeak**, operated entirely from OpenAI's cloud side, meaning local defenses could not intercept it.

[\[6\]](#)[\[7\]](#)[\[8\]](#)

- **Mitigation and Resolution:**
OpenAI patched the flaw in early August 2025, disabling Deep Research email integrations temporarily and adding sandbox restrictions preventing HTML parsing in automated agent modes. They further implemented **domain allow-lists**, **script sanitization**, and **behavioral monitoring** for all plug-in-based workflows. Security researchers confirmed no widespread data loss occurred.
[\[7\]](#)[\[8\]](#)[\[6\]](#)

3. OpenAI Account Credential Leak — February 2025, Re-emerging in August 2025 Sales

- **Attack Method:**
In February 2025, a threat actor named *Emirking* advertised **20 million OpenAI account credentials** for sale on BreachForums. These credentials, later linked to *infostealer logs* (such as RedLine and LummaC2), included tokens for ChatGPT and API access. The same data reappeared on underground marketplaces in **August 2025**, coinciding with a rise in targeted API abuse using stolen keys. Attackers used these credentials to automate ChatGPT sessions for phishing and data-scraping campaigns.
[\[9\]](#)[\[10\]](#)[\[11\]](#)
- **Mitigation and Resolution:**
OpenAI and credential-monitoring firms verified that most stolen accounts had been compromised through third-party infostealers rather than a direct platform breach. OpenAI enforced forced-logout sessions, mandatory password resets, and token invalidations. Security advisories recommended enabling multi-factor authentication and rotating API keys frequently.
[\[10\]](#)[\[11\]](#)[\[9\]](#)

Summary of Recency

Incident	Discovery Window	Latest Patch/Mitigation	Relative Recency
NPM Supply Chain Attack	September 4–12 2025	October 2025 security updates	Newest (ongoing)
ChatGPT ShadowLeak Exploit	August → September 2025	Fixed August 2025	Recent
OpenAI Credential Leak Resale	February → August 2025	Re-emerged August 2025	Moderately recent

REFERENCES

1. <https://www.crowdstrike.com/en-us/blog/crowdstrike-falcon-prevents-npm-package-supply-chain-attacks/>
2. <https://www.prventi.com/blog/the-npm-supply-chain-attack-of-september-2025>
3. <https://www.armorcode.com/blog/inside-the-september-2025-npm-supply-chain-attack>
4. <https://blog.qualys.com/vulnerabilities-threat-research/2025/09/10/when-dependencies-turn-dangerous-responding-to-the-npm-supply-chain-attack>
5. <https://unit42.paloaltonetworks.com/npm-supply-chain-attack/>
6. <https://wald.ai/blog/chatgpt-data-leaks-and-security-incidents-20232024-a-comprehensive-overview>
7. <https://thehackernews.com/2025/09/shadowleak-zero-click-flaw-leaks-gmail.html>
8. <https://www.malwarebytes.com/blog/news/2025/09/chatgpt-deep-research-zero-click-vulnerability-fixed-by-openai>
9. <https://zendata.security/2025/02/07/alleged-openai-data-breach-20-million-accounts-for-sale/>
10. <https://www.metomic.io/resource-centre/is-chatgpt-a-security-risk-to-your-business>
11. <https://www.kelacyber.com/blog/openai-breach/>
12. https://www.trendmicro.com/en_us/research/25/i/npm-supply-chain-attack.html
13. <https://www.sonatype.com/blog/ongoing-npm-software-supply-chain-attack-exposes-new-risks>
14. <https://www.tenable.com/blog/cybersecurity-snapshot-f5-breach-chatgpt-abuse-llm-attacks-ai-governance-10-17-2025>
15. <https://www.securityalliance.org/news/2025-09-npm-supply-chain>
16. <https://concentric.ai/chatgpt-security-risks-in-2025-a-guide-to-risks-your-team-might-be-missing/>
17. <https://openai.com/global-affairs/disrupting-malicious-uses-of-ai-june-2025/>
18. <https://www.paloaltonetworks.com/blog/cloud-security/npm-supply-chain-attack/>
19. <https://openai.com/index/response-to-nyt-data-demands/>
20. <https://www.wiz.io/blog/shai-hulud-npm-supply-chain-attack>